

LAPORAN HASIL AUTOMATED API TEST SUITE

"Smart Space Booking" - UKK RPL 2026/2027 Paket B, Kategori BACKEND

Dokumen ini adalah keluaran **Automated API Test Suite** berbasis **Playwright request fixture + TypeScript**. Seluruh angka di dalamnya diambil langsung dari hasil eksekusi suite (Playwright JSON reporter), bukan penulisan manual. Dibuat 20 September 2026 19:13.

1. Ringkasan Eksekutif

Sistem diuji murni pada lapisan HTTP/JSON (tanpa browser), mencakup 50 endpoint kontrak API Bagian III: root & health, multi-tenancy App Maker, autentikasi member/admin, katalog space dan diskon, pemesanan reservasi, CRUD admin, manajemen reservasi, laporan pendapatan, dan upload.

Dari **99 test case** yang dieksekusi berurutan dengan **workers=1** (agar dependensi data create-read-update-delete terjaga), **92 lolos** dan **7 gagal**. Seluruh 7 kegagalan adalah **temuan bug implementasi backend**, bukan kesalahan penulisan test: ekspektasi test dipertahankan sesuai kontrak soal dan tidak dilonggarkan agar lolos.

Item	Keterangan
Stack target uji	Node.js + Express + Prisma ORM + MySQL (http://localhost:3000)
Metode	Pure API testing - Playwright request context, tanpa browser / axe-core / lighthouse
Total test case	99
Lolos	92 (92.9%)
Gagal	7 (7.1%) - seluruhnya bug implementasi
Durasi eksekusi	55.9 detik
Critical bug	0 - isolasi multi-tenancy dan RBAC terbukti utuh
Reporter	html (playwright-report/) + list + json

2. Matriks Hasil Pengujian

Status diambil apa adanya dari report JSON. Kolom Catatan memuat pesan kegagalan pertama yang dikembalikan Playwright untuk test tersebut.

2.1 Fungsional B1-B2 - Root & Health

No	Test Case	Status	Catatan / Pesan Kegagalan
B1	B1: GET / - Status online	FAIL	Error: [2mexpect([22m[31mreceived[39m[2m).[22mtoBe[2m([22m[32mexpected[39m[2m) // Object.is equality[22m
B2	B2: GET /health - Server healthy status ok	FAIL	Error: [2mexpect([22m[31mreceived[39m[2m).[22mtoBe[2m([22m[32mexpected[39m[2m) // Object.is equality[22m

2.2 Fungsional B3-B7 - Multi-tenancy App Maker

No	Test Case	Status	Catatan / Pesan Kegagalan
B3	B3: Register App Maker - Sukses	PASS	
B4	B4: Register App Maker - Email/Username duplikat	FAIL	Error: [2mexpect([22m[31mreceived[39m[2m).[22mtoBe[2m([22m[32mexpected[39m[2m) // Object.is equality[22m
B5	B5: Login App Maker - Sukses & Gagal	PASS	
B6	B6: GET /api/maker/me tanpa token	PASS	
B7	B7: GET /api/maker/stats dengan x-maker-key valid	PASS	

2.3 Fungsional B8-B12 - Auth Member

No	Test Case	Status	Catatan / Pesan Kegagalan
B8	B8: Register member - Semua field wajib valid	PASS	
B9	B9: Register member - Field wajib kosong	FAIL	Error: Field 'instansi' yang kosong seharusnya mengembalikan status 400
B10	B10: Register member - Password < 6 karakter	PASS	
B11	B11: Register member - Username duplikat	FAIL	Error: [2mexpect([22m[31mreceived[39m[2m).[22mtoBe[2m([22m[32mexpected[39m[2m) // Object.is equality[22m
B12	B12: Register member TANPA header x-maker-key	PASS	

2.4 Fungsional B13-B16 - Auth Admin & Profile

No	Test Case	Status	Catatan / Pesan Kegagalan
B13	B13: Register admin-space - Sukses	PASS	
B14	B14: Login (member & admin) - Sukses & Gagal	PASS	
B15	B15: GET /api/auth/profile tanpa Bearer token	PASS	
B16	B16: GET /api/auth/profile dengan token member vs admin	PASS	

2.5 Fungsional B17-B22 - Katalog Space

No	Test Case	Status	Catatan / Pesan Kegagalan
B17	B17: GET /api/spaces/types - Array tepat 3 tipe	PASS	
B18	B18: GET /api/spaces?type=desk - Filter tipe	PASS	
B19	B19: GET /api/spaces?search=<kata kunci>	PASS	
B20	B20: GET /api/spaces/{id} valid vs invalid	PASS	
B21	B21: GET /api/spaces/availability - Slot kosong	PASS	
B22	B22: GET /api/spaces/availability - Slot yang sudah dibooking	PASS	

2.6 Fungsional B23-B24 - Katalog Diskon

No	Test Case	Status	Catatan / Pesan Kegagalan
B23	B23: GET /api/diskon/active - Hanya diskon aktif yang muncul	PASS	
B24	B24: POST /api/diskon/check - Kode valid vs kadaluarsa vs tidak ada	PASS	

2.7 Fungsional B25-B35 - Reservasi Member

No	Test Case	Status	Catatan / Pesan Kegagalan
B25	B25: Buat reservasi tanpa login -> 401	PASS	
B26	B26: Buat reservasi valid tanpa promo (kalkulasi harga)	PASS	
B27	B27: Buat reservasi dengan diskon/promo valid	PASS	
B28	B28: Buat reservasi slot bentrok (overlap id_space + tanggal + jam)	PASS	
B29	B29: Buat reservasi durasi_jam < 1 atau bukan integer	FAIL	Error: [2mexpect([22m[31mreceived[39m[2m).[22mtoBe[2m([22m[32mexpected[39m[2m) // Object.is equality[22m
B30	B30: jam_selesai terhitung otomatis dengan benar	PASS	
B31	B31: GET /api/reservasi/my hanya menampilkan reservasi milik member login	PASS	
B32	B32: GET /api/reservasi/my/history?month=&year=	PASS	
B33	B33: GET /api/reservasi/{id}/e-ticket	PASS	
B34	B34: PATCH /api/reservasi/{id}/cancel - Sukses lalu cancel lagi	PASS	
B35	B35: Member A akses GET /api/reservasi/{id} milik Member B -> 403/404	PASS	

2.8 Fungsional B44 - Admin Profile

No	Test Case	Status	Catatan / Pesan Kegagalan
B44	B44: PUT /api/admin/profile - Data profil berubah sesuai payload	PASS	
Admin Profile	Admin Profile: Guard tanpa Bearer token (401)	PASS	
Admin Profile	Admin Profile: Guard dengan Member Bearer token (403)	PASS	

2.9 Fungsional B36-B43 - Admin CRUD Member

No	Test Case	Status	Catatan / Pesan Kegagalan
B36	B36: POST /api/admin/members - Create member sukses (201)	PASS	
B37	B37: POST /api/admin/members - Field wajib kosong (400)	PASS	
B38	B38: GET /api/admin/members - List & search	PASS	
B39	B39: GET /api/admin/members/{id} - Valid vs Invalid	PASS	
B40	B40: PUT /api/admin/members/{id} - Partial update	PASS	
B41	B41: DELETE /api/admin/members/{id} lalu GET 404	PASS	
B42	B42: Admin Member endpoint TANPA Bearer token -> 401	PASS	
B43	B43: Admin Member endpoint dengan Member Bearer token -> 403	PASS	

2.10 Fungsional B36-B43 - Admin CRUD Space

No	Test Case	Status	Catatan / Pesan Kegagalan
B36	B36: POST /api/admin/spaces - Create space sukses (201)	PASS	
B37	B37: POST /api/admin/spaces - Tipe space salah / field kurang (400)	PASS	
B38	B38: GET /api/admin/spaces - List spaces	PASS	
B39	B39: GET /api/admin/spaces/{id} - Valid vs Invalid	PASS	
B40	B40: PUT /api/admin/spaces/{id} - Partial update	PASS	
B41	B41: DELETE /api/admin/spaces/{id} lalu GET 404	PASS	
B42	B42: Admin Space routes TANPA Bearer token -> 401	PASS	
B43	B43: Admin Space routes dengan Member Bearer token -> 403	PASS	

2.11 Fungsional B36-B43 - Admin CRUD Diskon

No	Test Case	Status	Catatan / Pesan Kegagalan
B36	B36: POST /api/admin/diskon - Create diskon valid (201)	PASS	
B37	B37: POST /api/admin/diskon - Validasi persentase > 100 & tanggal_akhir < tanggal_awal (400)	PASS	
B38	B38: GET /api/admin/diskon - List diskons	PASS	
B39	B39: GET /api/admin/diskon/{id} - Valid vs Invalid	PASS	
B40	B40: PUT /api/admin/diskon/{id} - Partial update	PASS	
B41	B41: DELETE /api/admin/diskon/{id} lalu GET 404	PASS	
B42	B42: Admin Diskon routes TANPA Bearer token -> 401	PASS	
B43	B43: Admin Diskon routes dengan Member Bearer token -> 403	PASS	

2.12 Fungsional B45-B50 - Manajemen Reservasi Admin

No	Test Case	Status	Catatan / Pesan Kegagalan
B45	B45: GET /api/admin/reservasi dengan kombinasi filter	PASS	
B46	B46: PATCH /api/admin/reservasi/{id}/status - Transisi valid (belum_dikonfirm -> disetujui)	PASS	
B47	B47: PATCH /api/admin/reservasi/{id}/status - Transisi ke status tidak dikenal (400)	PASS	
B48	B48: POST /api/admin/reservasi/{id}/check-in sebelum status disetujui (400)	PASS	
B49	B49: POST /api/admin/reservasi/{id}/check-in setelah disetujui -> 200, status aktif	PASS	
B50	B50: POST /api/admin/reservasi/{id}/check-out setelah aktif -> 200, status selesai	PASS	

2.13 Fungsional B51-B53 - Laporan Admin

No	Test Case	Status	Catatan / Pesan Kegagalan
B51	B51: GET /api/admin/reports/monthly?month&year	PASS	
B52	B52: GET /api/admin/reports/income konsisten dengan monthly	PASS	
B53	B53: Admin A tidak melihat data reservasi/space milik Admin B (beda maker)	PASS	

2.14 Fungsional B54-B56 - Upload

No	Test Case	Status	Catatan / Pesan Kegagalan
B54	B54: Upload file gambar valid (.png) ke endpoint upload	PASS	
B55	B55: Upload file bukan gambar (.txt)	PASS	
B56	B56: Upload tanpa file (field kosong)	PASS	

2.16 Security S1-S2 - Auth Guard

No	Test Case	Status	Catatan / Pesan Kegagalan
S1	S1: Akses endpoint terproteksi TANPA header Authorization -> konsisten 401	PASS	
S2	S2: Akses endpoint terproteksi dengan malformed Bearer token -> 401, bukan 500	PASS	

2.19 Security S7, S8, S10, S11 - Injection & Fuzzing

No	Test Case	Status	Catatan / Pesan Kegagalan
S7	S7: SQL Injection Payloads tidak menyebabkan bypass auth atau error 500 leak	PASS	
S8	S8: XSS Script tags disimpan sebagai string tanpa merusak response	PASS	
S10	S10: Payload Data Type Fuzzing menghasilkan 400 terkontrol, bukan 500	FAIL	Error: Payload fuzzing {"harga_per_jam":"string_bukan_angka","kapasitas":2,"nama_space":"Test Fuzz 1","tipe":"desk"} seharusnya merespons 400, bukan 500
S11	S11: Brute-force & Throttling evaluation on repeated failed logins	PASS	

2.18 Security S5-S6 - Multi-tenancy Isolation (KRITIS)

No	Test Case	Status	Catatan / Pesan Kegagalan
S5	S5: Query katalog & admin list Maker X tidak memunculkan data Maker Y	PASS	
S6	S6: Akses resource ID milik Maker Y menggunakan header x-maker-key milik Maker X -> 403/404	PASS	

2.20 Security S9 - Password Exposure Audit

No	Test Case	Status	Catatan / Pesan Kegagalan
S9.1	S9.1: Register Maker response tidak mengekspos password	PASS	
S9.2	S9.2: Login Maker response tidak mengekspos password	PASS	
S9.3	S9.3: Register Member response tidak mengekspos password	PASS	
S9.4	S9.4: Register Admin response tidak mengekspos password	PASS	
S9.5	S9.5: Login User (Member & Admin) response tidak mengekspos password	PASS	
S9.6	S9.6: GET /api/auth/profile response tidak mengekspos password	PASS	
S9.7	S9.7: GET /api/admin/members (list & detail) tidak mengekspos password	PASS	

2.15 Contract - Envelope Format Baku

No	Test Case	Status	Catatan / Pesan Kegagalan
Envelope format for 200 OK (GET /health)	Envelope format for 200 OK (GET /health)	PASS	
Envelope format for 201 Created (POST /api/auth/register/member)	Envelope format for 201 Created (POST /api/auth/register/member)	PASS	
Envelope format for 400 Bad Request (POST /api/maker/register with invalid data)	Envelope format for 400 Bad Request (POST /api/maker/register with invalid data)	PASS	
Envelope format for 401 Unauthorized (GET /api/auth/profile without token)	Envelope format for 401 Unauthorized (GET /api/auth/profile without token)	PASS	
Envelope format for 403 Forbidden (Member accesses Admin route)	Envelope format for 403 Forbidden (Member accesses Admin route)	PASS	
Envelope format for 404 Not Found (GET /api/non-existent-route)	Envelope format for 404 Not Found (GET /api/non-existent-route)	PASS	

2.21 Performance P1-P2 - Response Time

No	Test Case	Status	Catatan / Pesan Kegagalan
P1	P1: Response time GET katalog < 1000ms	PASS	
P2	P2: Response time kalkulasi reservasi & reporting < 1500ms	PASS	

2.17 Security S3-S4 - Role Isolation

No	Test Case	Status	Catatan / Pesan Kegagalan
S3	S3: Token Member dipakai ke endpoint admin -> konsisten 403 Forbidden	PASS	
S4	S4: Token Admin dipakai ke endpoint privat member (/api/reservasi/my)	PASS	

3. Daftar Bug dan Rekomendasi Perbaikan

Tujuh (7) test yang gagal dipetakan ke **5 akar masalah** berikut. Severity mengikuti dampak kontrak: Critical = kebocoran data antar maker atau bypass role; Major = validasi hilang atau status kode menyimpang dari kontrak; Minor = ketidaksesuaian kosmetik/edge case.

BUG-01 [Major] - Validasi field wajib pada registrasi member hilang

Test terkait: B9

Lokasi: src/controllers/authController.js (handler registerMember)

Gejala: Request registrasi member tanpa field instansi / alamat / telp tetap dijawab 201 Created dan nilainya tersimpan sebagai null.

Ekspektasi kontrak: username, password, nama_member, instansi, alamat, telp semuanya wajib; salah satu kosong harus 400 Bad Request.

Rekomendasi perbaikan:

```
if (!username || !password || !nama_member || !instansi || !alamat || !telp) {
  return sendResponse(res, 400, 'Field wajib tidak lengkap', null,
    'username, password, nama_member, instansi, alamat, dan telp diperlukan');
}
```

BUG-02 [Major] - durasi_jam desimal / non-integer diterima reservasi

Test terkait: B29

Lokasi: src/controllers/reservasiController.js (createReservasi)

Gejala: durasi_jam: 1.5 dipotong parseInt() menjadi 1 sehingga reservasi tetap dibuat (201) alih-alih ditolak.

Ekspektasi kontrak: durasi_jam wajib integer >= 1; nilai desimal, string, atau NaN harus 400 Bad Request.

Rekomendasi perbaikan:

```
const durasiNum = Number(durasi_jam);
if (!Number.isInteger(durasiNum) || durasiNum < 1) {
  return sendResponse(res, 400, 'Durasi tidak valid', null,
    'durasi_jam harus berupa bilangan bulat >= 1');
}
```

BUG-03 [Major] - Data-type fuzzing memicu unhandled 500 (PrismaClientValidationError)

Test terkait: S10

Lokasi: src/controllers/adminSpacesController.js (createSpace, jalur update serupa)

Gejala: harga_per_jam: "string_bukan_angka" -> parseFloat menghasilkan NaN -> diteruskan ke Prisma create -> 500 Internal Server Error, bukan error terkontrol.

Ekspektasi kontrak: Validasi tipe sebelum menyentuh ORM; balas 400 Bad Request terkontrol dan tanpa stack trace.

Rekomendasi perbaikan:

```
const harga = parseFloat(harga_per_jam);
const kap = parseInt(kapasitas);
if (isNaN(harga) || harga <= 0 || isNaN(kap) || kap <= 0) {
  return sendResponse(res, 400, 'Tipe data tidak valid', null,
    'harga_per_jam dan kapasitas harus berupa angka valid');
}
```

BUG-04 [Major] - Duplikasi username/email memakai 409 Conflict, kontrak meminta 400 Bad Request

Test terkait: B4, B11

Lokasi: src/controllers/makerController.js (register), src/controllers/authController.js (registerMember)

Gejala: Registrasi maker/member dengan username atau email yang sudah ada dijawab 409 Conflict dengan error: "Conflict".

Ekspektasi kontrak: Kontrak Bagian III menetapkan 400 Bad Request dengan error: "Bad Request" untuk duplikasi data.

Rekomendasi perbaikan:

Ubah statusCode 409 menjadi 400 pada cabang duplikasi, dan pastikan field error bernilai 'Bad Request' agar sesuai envelope baku.

BUG-05 [Minor] - Field data.status tidak ada pada endpoint root dan health

Test terkait: B1, B2

Lokasi: src/app.js (route GET / dan GET /health)

Gejala: GET / mengembalikan data { version, description, endpoints } dan GET /health mengembalikan data { uptime, environment, timestamp }; keduanya tanpa data.status.

Ekspektasi kontrak: GET / -> data.status === "online"; GET /health -> data.status === "ok".

Rekomendasi perbaikan:

Tambahkan status: 'online' pada objek data route GET /, dan status: 'ok' pada objek data route GET /health.

4. Kesimpulan

Multi-tenancy aman. Seluruh test isolasi (S5, S6) lulus: katalog space/diskon, daftar admin, dan akses langsung by-ID milik maker lain tidak pernah muncul atau terbuka ketika header x-maker-key milik maker berbeda dipakai.

RBAC konsisten. Endpoint /api/admin/* menolak token member dengan 403, dan endpoint privat member tidak dapat dipakai admin. Pemanggilan tanpa token maupun dengan token rusak konsisten 401 tanpa 500 atau hang.

Tanpa kebocoran kredensial. Deep-scan rekursif atas response register, login, profile, dan daftar/detail member membuktikan field password tidak pernah muncul, baik plainteks maupun hash.

Injeksi terkendali. Payload SQLi tidak dapat mem-bypass autentikasi (Prisma memparameterisasi query) dan payload XSS tersimpan sebagai string apa adanya tanpa merusak struktur response JSON.

Kinerja jauh di atas SLA. Endpoint katalog dan laporan merespons belasan milidetik, jauh di bawah ambang 1000 ms; endpoint berkalkulasi berada di bawah 1500 ms.

Lima perbaikan menuju suite hijau penuh. Semuanya validasi input dan pemetaan status kode di controller, tanpa perubahan skema database.

5. Limitasi dan Rekomendasi Lanjutan

Area	Penjelasan
Load & concurrency (race condition double-booking)	Playwright request context tidak dirancang untuk load testing sungguhan. Skrip k6 dengan ramp-up VU dan skenario tembak-serentak ke slot yang sama sudah disiapkan di tests/performance/load-note.md.
Full OWASP Top 10 scan	S7-S10 menutup injection, XSS, dan fuzzing tipe data. Pemindaian menyeluruh (header, CORS, SSRF, dependency, konfigurasi) disarankan lewat OWASP ZAP sebagai pelengkap.
Verifikasi algoritma hashing di level database	Black-box API testing tidak menjangkau isi tabel. Yang dibuktikan di sini adalah password tidak pernah bocor di response (S9); verifikasi bcrypt/argon2 dilakukan lewat inspeksi skema/DB, bukan lewat HTTP.
Rate limiting / brute-force throttling	Tidak ditemukan 429 pada login gagal beruntun (S11). Status tetap 401 konsisten, jadi bukan celah autentikasi, tetapi penambahan rate limiter tetap direkomendasikan.

6. Lampiran - Cara Menjalankan Ulang

Backend harus hidup dan API_BASE_URL pada .env menunjuk ke sana.

```
npm install
npm run dev # backend di http://localhost:3000
npx playwright test # seluruh suite (99 test)
npx playwright test tests/api --workers=1
npx playwright test tests/security
npx playwright test tests/performance
npx playwright show-report # buka report HTML
PLAYWRIGHT_JSON_OUTPUT_NAME=tmp/pw-results.json npx playwright test --reporter=html,json
python3 scripts/build-test-summary-pdf.py # regenerate PDF ini
```

Deliverable: TEST-SUMMARY.md, TEST-SUMMARY.pdf (dokumen ini), playwright-report/index.html, tests/performance/load-note.md (skrip k6 + skenario race condition double-booking).